



Information Security Policy

BluePeak Technologies | Enterprise information protection standard

Document ID	BPT-IT-SEC-011	Version	v2.0
Effective date	2026-08-01	Next review	2027-02-01
Owner	Information Security	Approved by	Executive Leadership Team and Security Steering Committee
Classification	Internal	Category	IT and Security
Audience	All employees	Status	Approved
Supersedes	BPT-IT-SEC-011 v1.0	Source	https://employee.bluepeaktech.com/resources/it-security/policies/information-security

Document purpose. BluePeak information classification, access control, encryption, data handling, approved AI use, secure development, third parties, incident reporting, business continuity, monitoring, and governance.

Contents

Security Essentials 3

1. Purpose and Scope 3

2. Security Principles 3

3. Roles and Accountability 4

 3.1 All Workforce Members 4

 3.2 Managers and Data Owners 4

 3.3 System and Application Owners 4

 3.4 Information Security 4

4. Information Classification 4

5. Data Lifecycle 4

 5.1 Collection and Creation 4

 5.2 Storage 5

 5.3 Use and Processing 5

 5.4 Sharing and Transfer 5

 5.5 Retention and Disposal 5

6. Identity and Access Management 5

7. Endpoint, Network, and Physical Security 5

8. Encryption and Key Management 6

9. Approved Artificial Intelligence and RAG Use 6

 9.1 Employee FAQ Chatbot Controls 6

 9.2 Safe AI Practice 6

10. Secure Software Development and Change 6

11. Cloud Services and Third Parties 7

12. Logging, Monitoring, and Privacy 7

13. Security Incident Reporting and Response 7

14. Business Continuity and Recovery 7

15. Exceptions, Enforcement, and Risk Acceptance 7

90. Administration, Exceptions, and Questions 8

91. Related Documents and Systems 8

Revision History 8

Security Essentials

Requirement	Employee action
Suspected incident	Report immediately to Security and no later than 24 hours after discovery; urgent threats should be reported by phone or the Security Hotline.
Restricted or Confidential data	Use only approved systems, least-privilege access, encryption, and authorized recipients.
Identity	Use the employee's own account, MFA, and approved password or passkey controls; never share credentials.
Devices	Use managed, encrypted devices for company work unless an approved BYOD exception applies.
Generative AI	Use only approved BluePeak AI services for company information; do not place Confidential or Restricted data in a public or personal AI service.
External sharing	Confirm the recipient, business purpose, classification, contract, and approved sharing method before sending.
Physical records	Minimize printing, secure records when unattended, and use approved destruction.

When uncertain, pause and ask: It is better to delay a file transfer, AI prompt, software installation, or vendor upload than to expose information that cannot be recovered.

1. Purpose and Scope

BluePeak protects the confidentiality, integrity, availability, and lawful use of information entrusted by employees, customers, partners, investors, and other stakeholders. This policy establishes the enterprise security framework for information in any form, location, or system.

It applies to employees, contractors, temporary workers, interns, vendors, and other authorized users of BluePeak information or technology. It covers company and customer data, source code, communications, paper records, cloud services, endpoints, networks, artificial intelligence systems, and physical facilities.

More specific standards may impose stronger requirements. Customer contracts, regulatory duties, legal holds, privacy notices, and local law take precedence where they are more protective.

2. Security Principles

BluePeak applies the following principles:

- 1 Least privilege: access only what is needed for the role and only for as long as needed.
- 1 Need to know: permitted access does not create a business reason to view or share information.
- 1 Defense in depth: identity, device, network, application, data, monitoring, and human controls work together.
- 1 Secure by design and default: products and internal systems begin with restrictive, tested settings.
- 1 Data minimization: collect, use, retain, and expose only what is necessary.
- 1 Separation of duties: sensitive approval, deployment, payment, and administrative actions should not depend on one person.
- 1 Verifiable trust: authenticate users and devices, authorize each request, log material activity, and review anomalies.
- 1 Resilience: prepare to maintain or restore critical services after failure, attack, or disaster.

3. Roles and Accountability

3.1 All Workforce Members

Every user is responsible for following training, protecting credentials and devices, classifying and handling data correctly, using approved services, challenging suspicious requests, and reporting incidents or control failures.

3.2 Managers and Data Owners

Managers request appropriate access, review it, remove it when duties change, and ensure staff understand applicable controls. Data owners define classification, permitted use, retention, sharing, and access groups. They do not override mandatory security or privacy requirements.

3.3 System and Application Owners

Owners maintain an inventory, risk classification, support model, business continuity plan, access reviews, patching, logging, backups, vendor records, and lifecycle plan. A system may not move to production without required security and privacy review.

3.4 Information Security

Information Security establishes standards, assesses risk, manages security architecture, monitors threats, coordinates incident response, validates control operation, advises teams, and reports material risk to leadership. Security may isolate a device, suspend access, block a service, or preserve records when needed to protect BluePeak.

4. Information Classification

BluePeak uses four classifications. The highest applicable classification controls a mixed record.

Classification	Description and examples	Minimum handling
Public	Approved for unrestricted release: published marketing, public job postings, public product documentation.	Verify publication approval; protect integrity and brand accuracy.
Internal	Routine nonpublic business information: internal procedures, team plans, ordinary directories, general training.	BluePeak access only unless owner approves; use approved storage and sharing.
Confidential	Material that could cause business, customer, employee, or legal harm: contracts, nonpublic financials, roadmaps, customer information, personnel records, security designs.	Named business need, approved encryption, controlled external sharing, logging where practical.
Restricted	Highest-impact information: credentials, private keys, regulated identifiers, payment-card data, health information, investigation files, production secrets, high-risk vulnerability data.	Explicit authorization, strongest approved encryption, tightly limited storage, enhanced logging, no routine email or local storage.

A document owner may apply a stricter label. Unlabeled nonpublic information should be treated as Internal until classified. Personal data may be Confidential or Restricted depending on sensitivity and context.

5. Data Lifecycle

5.1 Collection and Creation

Collect only data needed for a defined purpose. Inform individuals as required, use approved forms and systems, and avoid free-text collection of sensitive data when structured fields or a secure workflow exists. Do not place Social Security numbers, medical details, passwords, or payment credentials into ordinary notes, chat, or email.

5.2 Storage

Store BluePeak information in approved repositories with appropriate access control, backup, retention, and monitoring. Personal cloud storage, consumer file-sharing, unapproved source repositories, and local removable media are not approved for company records.

Restricted data may be stored only in systems specifically authorized for that data type. Encryption keys and secrets must be kept in the approved secrets-management service, not in source code, documents, tickets, or chat.

5.3 Use and Processing

Use information only for the authorized business purpose. Exporting, copying, mass downloading, or combining data can increase risk and may require owner approval. Production data should not be used in development, demonstrations, or testing unless specifically approved and minimized, masked, or synthesized.

5.4 Sharing and Transfer

Before sharing, verify the recipient, classification, purpose, minimum necessary content, contractual basis, and approved channel. External recipients must be bound by suitable confidentiality, security, and privacy terms. Links should expire or be revoked when the purpose ends.

Email auto-complete, public Teams channels, anonymous links, and open distribution lists require special care. A recipient's role or seniority does not eliminate the need to know.

5.5 Retention and Disposal

Retain records according to the corporate retention schedule, legal holds, contracts, and regulatory requirements. Do not retain data "just in case." At end of life, use approved deletion, cryptographic erasure, media destruction, or confidential shredding. Deleting a local copy does not remove records from a system of record or backup.

6. Identity and Access Management

Access must be uniquely assigned, authenticated through Microsoft Entra ID or another approved identity provider, protected by MFA, and authorized by role and business need. Shared accounts are prohibited unless Security approves a technical exception with named accountability and credential controls.

Managers and owners review privileged and sensitive access at least quarterly and other access at least annually. Access is modified promptly after transfer and disabled no later than the employee's separation time. Dormant, orphaned, guest, and service accounts are reviewed and removed.

Privileged administration should use a separate account, just-in-time activation, strong MFA, approved workstation, logging, and change authorization. Emergency access accounts are tightly controlled and tested.

7. Endpoint, Network, and Physical Security

Company devices must use approved configuration, encryption, endpoint protection, screen lock, patching, and remote management. Users may not disable security software, jailbreak a device, share it with household members, or install unauthorized administrative tools.

Use approved networks and VPN or private access controls when required. Public Wi-Fi is not trusted. Restricted work should not be performed where a screen or conversation can be observed. Secure doors, badges, keys, and visitor processes must be followed; tailgating should be challenged safely or reported.

Lost or stolen devices, badges, security keys, or records must be reported immediately. Do not delay reporting while searching.

8. Encryption and Key Management

Confidential and Restricted data must be encrypted in transit and at rest using approved protocols and services. Restricted data sent externally requires a specifically approved transfer method. Users should not invent passwords for ZIP files or exchange decryption secrets in the same channel without guidance.

Keys, certificates, tokens, API credentials, and secrets must have an owner, approved storage, least-privilege access, rotation or expiration, monitoring, and revocation process. Production secrets must never appear in source code, CI logs, screenshots, tickets, or AI prompts.

9. Approved Artificial Intelligence and RAG Use

BluePeak permits AI use when the service, data, purpose, and human oversight are approved. Employees may use the Employee FAQ Chatbot and other approved enterprise AI services within their designed scope. Personal or public AI accounts may not receive BluePeak Internal, Confidential, Restricted, customer, source-code, or personal data.

9.1 Employee FAQ Chatbot Controls

The Employee FAQ Chatbot authenticates users through Microsoft Entra ID and generates answers from approved HR documents indexed for retrieval. The following controls apply:

- 1 documents require owner, classification, visibility, version, and HR approval before becoming searchable;
- 1 retrieval must apply the user's authorized groups or document permissions before content is provided to the model;
- 1 answers should cite the source document and relevant section;
- 1 a low-confidence or unsupported answer should direct the employee to HR rather than invent a rule;
- 1 chat history is retained only for the approved operational period and is not an official personnel record;
- 1 sensitive employee-specific decisions require an authorized human review; and
- 1 uploads, prompts, outputs, citations, administrative actions, and access failures are logged according to the approved security design.

A chatbot response does not replace the controlling policy, plan document, employment agreement, legal advice, or an individualized determination by People Operations.

9.2 Safe AI Practice

Users must review AI output for accuracy, bias, confidentiality, licensing, security, and appropriateness. AI-generated code, analysis, or text receives the same review as human work. Employees may not use AI to impersonate a person, make an unreviewed employment decision, conduct covert monitoring, create misleading evidence, or bypass a control.

Prompt injection, unexpected source content, fabricated citations, data leakage, unsafe code, or anomalous model behavior should be reported to Security and the application owner.

10. Secure Software Development and Change

Applications must use approved repositories, code review, dependency and secret scanning, protected branches, testing, environment separation, change records, and deployment controls proportionate to risk. Security requirements and threat modeling should begin during design, not after release.

Critical vulnerabilities and exposed secrets require immediate escalation. Security sets remediation timelines based on severity, exploitability, exposure, and compensating controls. An exception requires a documented owner, risk, control, expiration date, and approval.

Production access is limited, logged, and separated from routine development. Changes to authentication, authorization, encryption, audit logging, payments, HR data, customer data, or AI retrieval permissions require heightened review.

11. Cloud Services and Third Parties

A service must complete Procurement, Legal, Security, and Privacy review as applicable before company data or credentials are provided. Review considers data location, subcontractors, access, encryption, logging, incident notice, deletion, resilience, financial viability, AI use, and contractual rights.

Business owners monitor material vendors and notify Security of scope changes, incidents, acquisitions, or termination. Vendor accounts are individually assigned where possible and removed when access is no longer needed. A free trial is not an exception to review.

12. Logging, Monitoring, and Privacy

BluePeak logs and monitors systems, identities, devices, networks, repositories, cloud services, and business applications to protect security, investigate misuse, satisfy legal obligations, and operate services. Monitoring is risk-based and limited to legitimate purposes.

Users should have no expectation that company systems are private from authorized business review, but BluePeak respects legal privacy rights and limits access to personnel with a need. Security logs are protected from alteration and retained according to the security and records schedule.

13. Security Incident Reporting and Response

Report suspected or actual incidents immediately and no later than 24 hours after discovery. Examples include phishing, malware, misdirected email, lost device, unauthorized access, accidental public link, suspicious login, exposed secret, customer-data concern, policy bypass, unusual AI output, and physical intrusion.

Use the Security Hotline, incident button, or security@bluepeaktech.com. For an immediate physical emergency, call local emergency services first. Do not investigate beyond safe fact gathering, delete evidence, contact an attacker, make a public statement, or promise a customer notification.

Security coordinates containment, preservation, analysis, legal and privacy review, communication, recovery, and lessons learned. Employees must cooperate and preserve relevant records. Good-faith reporting is protected from retaliation.

14. Business Continuity and Recovery

Critical systems must have documented recovery objectives, backups, dependencies, communication paths, and tested restoration. Backups must be protected from the same identity or ransomware event that affects production. Owners test continuity and recovery at a frequency based on risk.

During an incident, Security or executive leadership may restrict access, isolate systems, suspend integrations, invoke manual processes, or prioritize critical customer and employee services.

15. Exceptions, Enforcement, and Risk Acceptance

A security exception must be requested before noncompliance when practical and must document scope, business need, threat, affected data, compensating controls, owner, expiration date, and remediation plan. Only the authorized risk owner and Information Security may accept the risk; a project deadline alone is not approval.

Violations may result in access restriction, retraining, corrective action up to termination, contract remedies, recovery of loss, and legal referral. Enforcement considers intent, impact, recurrence, cooperation, and applicable law.

90. Administration, Exceptions, and Questions

BluePeak administers information security consistently with the employee's work location, employment classification, written employment terms, and applicable law. A statutory or contractual entitlement that is more generous than this document will apply to the extent required. A manager may not waive a legal requirement, create a new benefit, or promise an exception without written approval from the document owner.

Employees should raise questions before relying on an informal interpretation. Contact security@bluepeaktech.com through Outlook or the People Help channel in Microsoft Teams. Payroll, Legal, Information Security, or a site leader will be consulted when the question involves tax, wage-and-hour, privacy, immigration, safety, or local-law considerations.

Approved exceptions must identify the employee, the policy provision, the business reason, the approving authority, the start and end date, and any conditions. Exceptions are stored with the employee or transaction record and do not establish a precedent for other employees.

91. Related Documents and Systems

Resource	When to use it
Password & Account Security Policy	Passwords, passkeys, MFA, account recovery, privileged access, and lifecycle.
Acceptable Use of Company Devices	Permitted technology use, software, monitoring, BYOD, and return.
Company Code of Conduct	Confidentiality, accurate records, investigations, and non-retaliation.
Remote Work Policy	Approved work locations, networks, workspace privacy, and international access.
Workplace Safety & Emergency Procedures	Physical security, emergency response, and business continuity.

Revision History

Version	Effective date	Change summary
v2.0	2026-08-01	Added approved AI and RAG controls, document-level authorization, cloud and vendor safeguards, and clarified incident reporting and data classification.